FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

10 of the 49 fraud schemes that apply have a control reported as a gap, most of them in digital channels.

78.5 / 100 **STRUCTURED**

Calculated figure, a test fixture. Not an approved score or readiness conclusion.

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

Assessment date · 12 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL OWNER-MANAGED FIRM

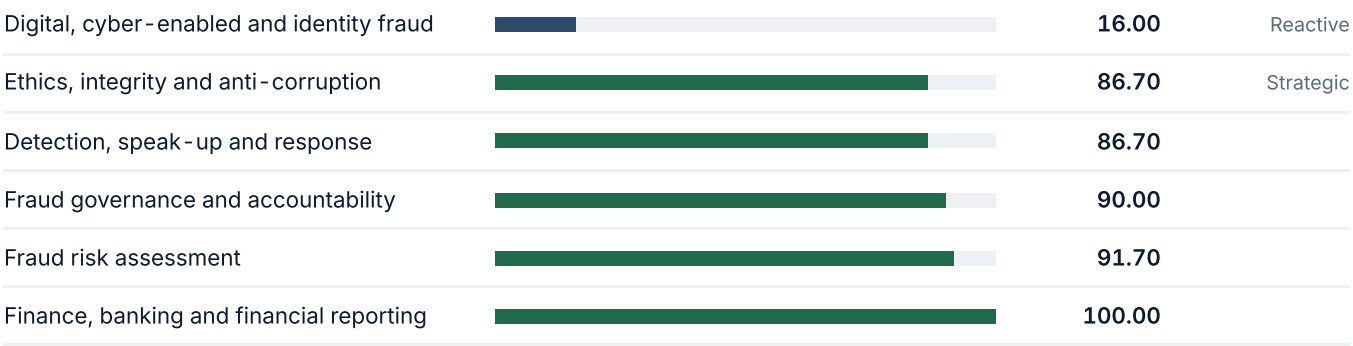
WHAT DOES THE ASSESSMENT SHOW?

Fraud readiness at a glance

78.5	Structured	6	100.00	16.00
CALCULATED FIGURE (TEST FIXTURE)	MATURITY BAND	DOMAINS ASSESSED	STRONGEST DOMAIN	WEAKEST DOMAIN
			Finance, banking & financial reporting	Digital, cyber-enabled & identity fraud

49 fraud schemes apply to the organisation, 2 of which the method does not ask about at its size. For 36, every control asked about was reported in place, and for 1 the control that stops the scheme is reported in place while a further defence is weaker. 10 have a control reported as a gap, 4 of them in tier 1, the schemes the draft method confirms in its core stage. The core stage is complete; all 47 schemes asked about can be analysed in full from the answers given. The calculated figure above is a test fixture from a research simulation, not an approved score or readiness conclusion.

Domain readiness profile



Ordered weakest first. Calculated figures from a research simulation (test fixtures), not approved scores.

WHY DOES THE POSITION LOOK LIKE THIS?

What the answers show

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Digital, cyber-enabled and identity fraud: 10 schemes with a control reported as a gap	Multi-factor on all email **Not in place** Email never enough on its own **Not in place** Verification for calls, voice notes and video **Partly in place**	Most business email compromise starts with an account that has no multi-factor authentication. The same area also has open: a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed.
1 scheme: control in place, a further defence weaker	Training on joining **Partly in place**	Each weaker practice is a separate defence against the same scheme. The control that stops the scheme stands as reported; the practices are listed in the register.

THE PATTERN THAT MATTERS

In the one scheme where a control was reported fully in place and a practice of the same scheme weaker, the method's wording shows the practice is a separate defence, so the reported control stands as given. Separately, 5 of 24 controls that can be cross-checked were asked one further question: 5 consistent, 0 conflicting and 0 with a separate practice reported weaker. These compare the organisation's own answers; they are not tests of operation and change no figure.

WHERE DOES FRAUD EXPOSURE MATTER MOST?

Fraud schemes the answers point to

#	FRAUD SCHEME	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	WHY IT IS LISTED
1	**An email account is taken over** A mailbox without strong sign-in is used to send or intercept payment instructions.	Multi-factor on all email **Not in place**	Most business email compromise starts with an account that has no multi-factor authentication.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	**Gap, tier 1** Its control is reported as not in place.
2	**A payment instruction received by email is acted on** Changed details or urgent payments are processed on the strength of an email.	Email never enough on its own **Not in place**	Acting on payment instructions received by email is how business email compromise succeeds.	Email never enough on its own: in place	**Gap, tier 1** Its control is reported as not in place.
3	**A cloned voice or video instruction is obeyed** A caller who sounds or looks like a known person is believed.	Verification for calls, voice notes and video **Partly in place**	Voices and faces can be cloned, so only an agreed verification method holds.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.	**Gap, tier 1** Its control is reported as partly in place.
4	**A security compromise is not notified** The Regulator and affected people are not told, so they cannot protect themselves.	Compromises reported as POPIA requires **Partly in place**	POPIA section 22 requires notification as soon as reasonably possible.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	**Gap, tier 1** Its control is reported as partly in place.
5	**A help desk reset hands an attacker access** An impersonator persuades the help desk to reset a password or authenticator.	Help desk resets verified **Partly in place**	The method links it to social engineering of the IT help desk and takeover of staff accounts.	Help desk resets verified: in place	**Gap, tier 2** Its control is reported as partly in place.

Listed with answers to resolve first, then one scheme with a control reported as a gap from each area, areas with the most such schemes first. This is a presentation order: MK has not approved a method for rating fraud risks, and every scheme is in the register.

HOW COULD THAT EXPOSURE MATERIALISE?

How the schemes would work here

An email account is taken over

A mailbox without strong sign-in is used to send or intercept payment instructions › Multi-factor on all email not in place › Takeover of staff accounts

A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication. Here, email accounts are protected by passwords only.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

Warning signs: Takeover of staff accounts · Business email compromise and payment redirection

A payment instruction received by email is acted on

Changed details or urgent payments are processed on the strength of an email › Email never enough on its own not in place › Business email compromise and payment redirection

Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds. Here, payment changes received by email are acted on as received.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

Warning signs: Business email compromise and payment redirection

A cloned voice or video instruction is obeyed

A caller who sounds or looks like a known person is believed › Verification for calls, voice notes and video partly in place › Deepfake voice and video impersonation of executives and staff

A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds. Here, some staff check unusual requests, depending on their own judgement.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.

Warning signs: Deepfake voice and video impersonation of executives and staff

These are plausible schemes for an organisation with the controls it reported. They are not allegations that these events have occurred.

WHAT DOES MANAGEMENT NEED TO CHANGE?

What management should address first

#	MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
1	**Name an owner for each area and decide the order of work**	The draft method does not rank fraud risks by likelihood or impact, so this report does not either. Which of the 10 open schemes to address first is management's decision, informed by its own volumes and values.	Chief executive	Each area with open schemes has one accountable executive, and the order of work is recorded with the reason for each choice.
2	**Put in place: multi-factor on all email**	Stops the scheme where an email account is taken over. Its control is reported as not in place.	IT lead	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
3	**Put in place: email never enough on its own**	Stops the scheme where a payment instruction received by email is acted on. Its control is reported as not in place.	IT lead	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
4	**Put in place: verification for calls, voice notes and video**	Stops the scheme where a cloned voice or video instruction is obeyed. Its control is reported as partly in place.	Chief financial officer	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
5	**Put in place: compromises reported as POPIA requires**	Stops the scheme where a security compromise is not notified. Its control is reported as partly in place.	IT lead	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
6	**Put in place: help desk resets verified**	Stops the scheme where a help desk reset hands an attacker access. Its control is reported as partly in place.	IT lead	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.

WHAT SHOULD HAPPEN IN THE FIRST 90 DAYS?

The first 90 days

The windows order the work by what must be known and decided before controls are designed. They set no deadline from a scheme's tier or the answers given; dates are management's decision.

30 days: Establish the facts and owners

0–30 DAYS

Answers that conflict are resolved, outstanding answers are obtained and each area with open schemes has an accountable executive.

Name the accountable executive for each area with open schemes, and decide which schemes to address this cycle. — Chief executive

Named executives and a recorded order of work.

Complete when: Every open scheme is selected, deferred with a reason or accepted at the right level.

60 days: Design the controls, prerequisites first

31–60 DAYS

Approved designs exist for the schemes management selected, with the controls others rely on designed first.

Approve the target design for each selected scheme, using the standards in this report. — Each accountable executive

Approved designs, each with an owner and the records it will keep.

Complete when: Each selected control has an approved design and a named owner.

90 days: Start operating and report

61–90 DAYS

The first designed controls operate for a full cycle and the oversight body sees the status of every scheme.

Start operating the approved designs and review the first full cycle against the success measures. — Each process owner

A first-cycle review for each control, with exceptions and their resolution.

Complete when: Each control has met its success measure for one cycle, or has a recorded correction.

Report the status of each open and unresolved scheme to the owners. — Chief executive

A one-page status per scheme: owner, controls in place, controls outstanding, next step.

Complete when: The status is received and minuted.

HOW WILL MANAGEMENT KNOW WHETHER READINESS IS IMPROVING?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Multi-factor on all email	Email accounts are protected by passwords only.	Records for the period show that multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
Email never enough on its own	Payment changes received by email are acted on as received.	Records for the period show that an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
Verification for calls, voice notes and video	Some staff check unusual requests, depending on their own judgement.	Records for the period show that an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
Open schemes with a named owner and a decision	None recorded in the assessment (10 open).	Each selected, deferred with a reason or accepted at the right level.

Management conclusion

Fictional Owner-Managed Firm's answers show 37 schemes with the controls that stop them reported in place and 10 with a control reported as a gap, most of them in digital channels. The draft method does not yet rank fraud risks, so the order of the remaining work is management's decision; the supporting register lists every scheme, control and record behind this report.

This report is based on the organisation's own answers to the MK Fraud Readiness review, given by the respondent and the accountable functions named in it, and read against the draft review method, which MK has not yet approved. MK has not independently tested whether controls operate in practice, and no evidence was reviewed; evidence review is a separate Advisory service. The records named in this report are records management should maintain; MK has not requested or examined them. TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.